COMPTE-RENDU DE TRAVAUX PRATIQUES : TP09

Mise en place d'un serveur Web / FTP dédié sous Ubuntu Light

1. Contexte et Objectifs du TP

Dans le cadre des activités d'infrastructure de Galaxy Swiss Bourdin (GSB), l'objectif de ce travail pratique est de déployer et de sécuriser un serveur dédié assurant à la fois les fonctions de serveur Web et de serveur de transfert de fichiers (FTP).
Les objectifs opérationnels sont :

- Activer et administrer à distance le serveur via le protocole sécurisé SSH.
- Déployer une pile Web complète LAMP (Linux, Apache2, MySQL, PHP5) ainsi que l'interface phpMyAdmin.
- Installer et configurer un serveur FTP (Pure-FTPd) fonctionnant avec des utilisateurs virtuels.
- Sécuriser l'ensemble des échanges FTP par l'implémentation du protocole TLS (FTPS).
- Sécuriser les flux Web par le protocole HTTPS via la mise en place d'un certificat SSL sur Apache.
- Forcer la redirection permanente des requêtes HTTP (port 80) vers HTTPS (port 443).
- Valider le bon fonctionnement de l'infrastructure par des tests de recette complets.

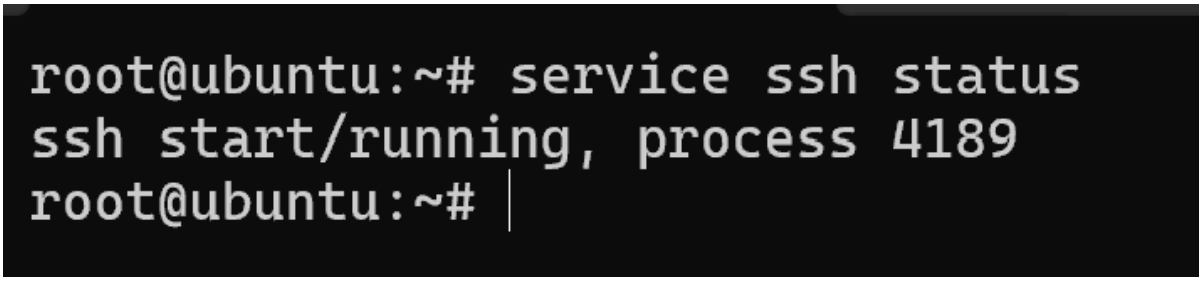
2. Architecture et Plan d'Adressage Réseau

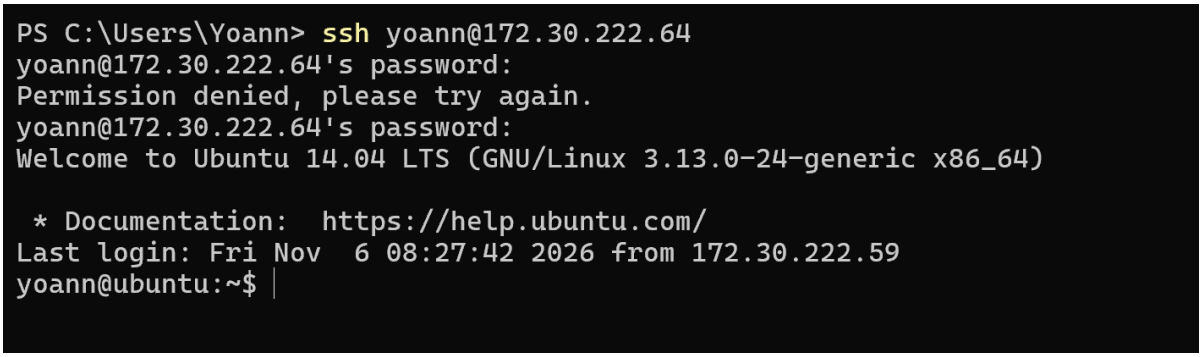
- **Serveur dédié :** Ubuntu Light (Ubuntu 14.04 Trusty), adresse IP fixe : 172.30.222.64
- **Poste client :** Machine hôte Windows (PowerShell, FileZilla, Navigateur Web)

3. Déroulement et Mise en Œuvre Technique

A. Prérequis, connectivité réseau et administration SSH

- Diagnostic et résolution des blocages APT : correction de la syntaxe de configuration proxy dans /etc/apt/apt.conf, rétablissement de l'accès réseau et mise à jour de la liste des paquets.
- Configuration du service OpenSSH Server : création d'un utilisateur d'administration 'yoann' membre du groupe sudo, initialisation du mot de passe root et lancement du service via le système d'initialisation SysVinit.





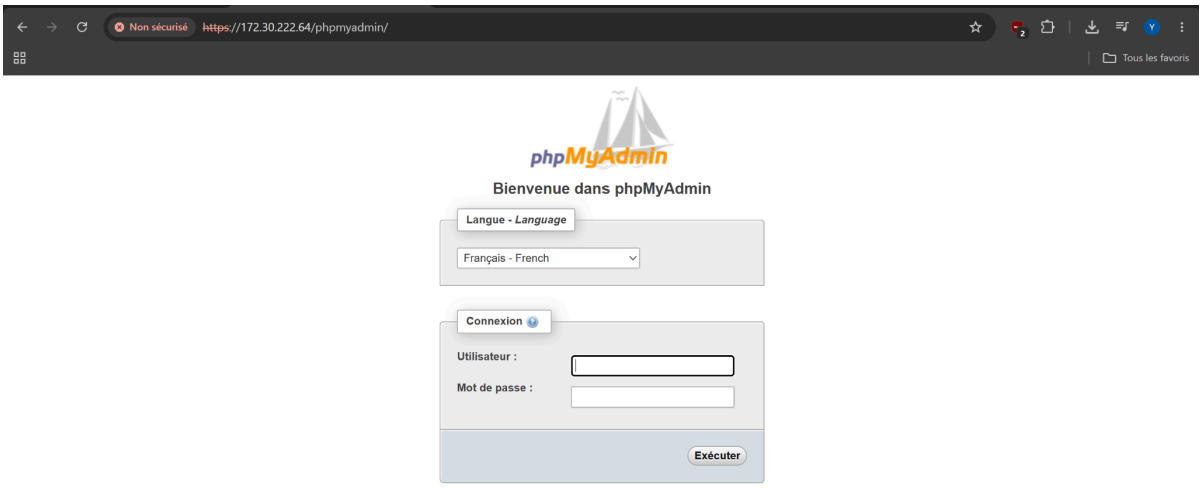
B. Déploiement du Serveur Web (LAMP) et phpMyAdmin

- Installation d'Apache2, MySQL Server et de l'interpréteur PHP5 adapté à la version Ubuntu Trusty.
- Validation de l'exécution PHP par la création d'une page phpinfo.

[capture d'écran + la commande : service apache2 status]
[capture d'écran + la commande : curl -I http://localhost/info.php ou capture navigateur sur http://172.30.222.64/info.php]

- Déploiement de l'outil d'administration phpMyAdmin et intégration dans la configuration Apache via /etc/apache2/apache2.conf.

```
root@ubuntu:~# ls /etc/phpmyadmin
apache.conf  config-db.php          config.header.inc.php  htpasswd.setup  phpmyadmin.desktop
conf.d       config.footer.inc.php  config.inc.php         lighttpd.conf   phpmyadmin.service
root@ubuntu:~#
```



C. Déploiement du Serveur FTP (Pure-FTPd)

- Installation des paquets pure-ftpd et pure-ftpd-common.
- Sécurisation du service : désactivation de l'authentification PAM système et activation du mécanisme PureDB pour la gestion d'utilisateurs virtuels isolés.
- Création de l'utilisateur système technique 'ftpuser' (groupe 'ftpgroup') sans shell d'accès.
- Création du compte virtuel 'gsbuser' avec pour répertoire racine /home/ftp/gsb.

```
root@ubuntu:~# pure-pw list
gsbuser                    /home/ftp/gsb/./
root@ubuntu:~#
```

```
root@ubuntu:~#  service pure-ftpd status
 * pure-ftpd is running
root@ubuntu:~#
```

D. Sécurisation du serveur FTP (TLS / FTPS)

- Génération d'une clé RSA de 2048 bits et d'un certificat X.509 auto-signé dédié au démon FTP (/etc/ssl/private/pure-ftpd.pem).
- Attribution des droits stricts (chmod 600) et forçage de la directive TLS dans /etc/pure-ftpd/conf/TLS.

```
root@ubuntu:~#  ls -l /etc/ssl/private/pure-ftpd.pem
-rw------- 1 root root 2933 Nov  6 08:35 /etc/ssl/private/pure-ftpd.pem
root@ubuntu:~#
```

```
root@ubuntu:~# cat /etc/pure-ftpd/conf/TLS
1
root@ubuntu:~#
```

E. Sécurisation Web (HTTPS) et Redirection Permanente

- Activation des modules Apache indispensables : mod_ssl et mod_rewrite.
- Génération de la paire de clés et du certificat auto-signé Apache (/etc/ssl/certs/gsbserver.crt et /etc/ssl/private/gsbserver.key).
- Création du VirtualHost sécurisé gsb-ssl.conf sur le port 443 pointant vers /var/www/html avec directives SSLEngine.
- Modification du VirtualHost par défaut 000-default.conf sur le port 80 avec la directive de redirection permanente : Redirect permanent / https://172.30.222.64/.
- Rechargement de la configuration Apache.

```
root@ubuntu:~# cat /etc/apache2/sites-available/gsb-ssl.conf
<VirtualHost *:443>
    ServerName 172.30.222.64
    DocumentRoot /var/www/html

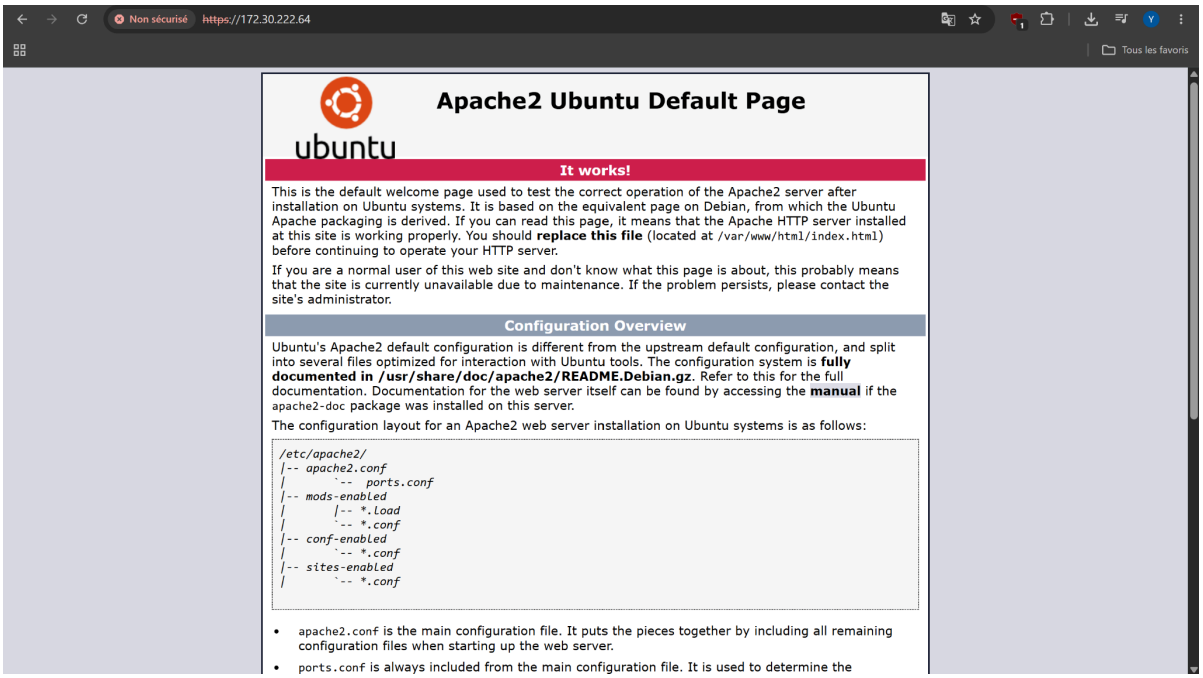
    SSLEngine on
    SSLCertificateFile /etc/ssl/certs/gsbserver.crt
    SSLCertificateKeyFile /etc/ssl/private/gsbserver.key

    ErrorLog ${APACHE_LOG_DIR}/error_ssl.log
    CustomLog ${APACHE_LOG_DIR}/access_ssl.log combined
</VirtualHost>
root@ubuntu:~#
```

```
root@ubuntu:~# cat /etc/apache2/sites-available/000-default.conf
<VirtualHost *:80>
    ServerName 172.30.222.64
    Redirect permanent / https://172.30.222.64/
</VirtualHost>
root@ubuntu:~#
```

4. Phase de Recette et Validation

- Test 1 (Redirection Web) : Vérification de la bascule automatique d'une requête HTTP non chiffrée vers l'URL HTTPS sécurisée.



- Test 2 (phpMyAdmin) : Authentification réussie sur l'interface de gestion de base de données sous connexion chiffrée HTTPS.

[capture d'écran + la commande : navigateur affichant phpMyAdmin sur https://172.30.222.64/phpmyadmin/]

- Test 3 (FTPS) : Connexion depuis le client FileZilla sur le port 21, acceptation du certificat TLS et téléversement concluant d'un fichier dans le répertoire distant.

5. Bilan et Compétences Mises en Œuvre

Le travail réalisé a permis de mettre en place une solution robuste et sécurisée répondant aux besoins du contexte GSB :

- Chiffrement systématique des flux d'administration et d'échange (SSH, HTTPS, TLS).
- Cloisonnement des accès FTP par comptes virtuels pour préserver la sécurité de l'OS hôte.
- Adaptation fine de la configuration aux contraintes de la distribution Ubuntu Light.

6. Analyse Approfondie de la Sécurité et Durcissement (Hardening)

A. Vulnérabilités du protocole FTP et apport de FTPS (TLS)

Le protocole FTP traditionnel (RFC 959) transmet l'intégralité des identifiants (nom d'utilisateur et mot de passe) ainsi que les données en clair sur le réseau. Dans un

environnement partagé ou exposé, un attaquant positionné sur le segment réseau peut procéder à une attaque d'interception par reniflage de paquets (packet sniffing), lui permettant de capturer les identifiants d'authentification sans altération visible du service.
L'implémentation de FTPS (FTP sur TLS, RFC 4217) résout cette vulnérabilité majeure en instaurant une couche de chiffrement de bout en bout avant toute phase d'authentification. Les apports clés sont :

- **Confidentialité des identifiants et des données :** Chiffrement du canal de commande (port 21) et du canal de données via TLS 1.2+.
- **Authentification du serveur :** Présentation d'un certificat X.509 permettant au client de valider l'identité du serveur avant le transfert de données.
- **Intégrité des transferts :** Contrôle par mécanismes d'authentification de message (MAC) prévenant toute altération ou injection malveillante durant le transfert.

B. Isolation des accès par comptes virtuels PureDB

Dans une configuration FTP standard reposant sur la base d'utilisateurs système (PAM / /etc/passwd), l'obtention des identifiants d'un compte FTP confère potentiellement un accès shell au système d'exploitation hôte. En cas de faille de sécurité ou de mot de passe faible, le serveur complet risque d'être compromis.
Pour pallier ce risque, l'architecture retenue s'appuie sur le moteur d'utilisateurs virtuels PureDB de Pure-FTPd :

- **Absence de compte système :** Les utilisateurs virtuels (tels que 'gsbuser') n'existent pas dans /etc/passwd et ne disposent d'aucun interpréteur de commandes (shell) sur l'OS.
- **Mappage système restreint :** Toutes les actions des utilisateurs virtuels sont associées à un compte système unique et fortement restreint ('ftpuser', groupe 'ftpgroup'), privé de privilèges d'administration.
- **Chroot strict :** Chaque utilisateur virtuel est strictement enfermé (chrooted) dans son répertoire dédié (/home/ftp/gsb), rendant impossible l'arborescence système globale.

C. Sécurisation et durcissement du serveur Web Apache

Afin d'appliquer les principes de défense en profondeur, le serveur Apache2 a fait l'objet d'un durcissement de sa configuration standard :

- **Masquage de la bannière système (ServerTokens Prod et ServerSignature Off) :** Par défaut, Apache divulgue sa version exacte et le nom de la distribution dans les en-têtes de réponse HTTP ainsi que sur les pages d'erreur. La restriction à 'Prod' masque ces métadonnées et limite l'empreinte réseau (fingerprinting) exploitable par un attaquant.

- **Désactivation du listage automatique des répertoires (Options -Indexes) :** Empêche l'affichage du contenu des dossiers web dépourvus de fichier index (index.php ou index.html), protégeant ainsi l'arborescence des scripts et fichiers sensibles contre l'exploration non autorisée.

D. Chiffrement Web HTTPS et impact des certificats auto-signés

Le passage de HTTP à HTTPS (port 443) garantit la confidentialité des échanges Web, la protection contre les attaques de type Man-In-The-Middle (MITM) et l'intégrité des requêtes et réponses.
Dans le cadre du laboratoire TP09, un certificat X.509 auto-signé a été généré. Il convient de distinguer ce type de certificat d'un certificat émis par une autorité de certification (CA) publique :

- **Certificat auto-signé :** Assure le chiffrement complet du canal de communication. Cependant, faute de chaîne de confiance validée par une CA racine (ex. Let's Encrypt, DigiCert), le navigateur affiche un avertissement de sécurité. Adapté exclusivement aux phases de test, dev et recettes internes.
- **Certificat signé par une CA publique :** Garantit à la fois le chiffrement des données et l'authentification irréfutable du domaine auprès des navigateurs clients sans alerter l'utilisateur. Requis pour la mise en production.

7. Journalisation, Débogage et Analyse des Logs

A. Surveillance des connexions et erreurs Apache2

L'analyse continue des journaux du serveur Web permet de contrôler l'activité des utilisateurs et d'identifier rapidement toute tentative d'intrusion ou dysfonctionnement des applications web (ex. phpMyAdmin).

```
root@ubuntu:~# tail -n 20 /var/log/apache2/access.log
::1 - - [06/Nov/2026:08:32:31 +0000] "OPTIONS * HTTP/1.0" 200 125 "-" "Apache/2.4.7 (Ubuntu) PHP/5.5.9-1ubuntu4.29 (internal dummy connection)"
::1 - - [06/Nov/2026:08:32:31 +0000] "OPTIONS * HTTP/1.0" 200 125 "-" "Apache/2.4.7 (Ubuntu) PHP/5.5.9-1ubuntu4.29 (internal dummy connection)"
::1 - - [06/Nov/2026:08:32:31 +0000] "OPTIONS * HTTP/1.0" 200 125 "-" "Apache/2.4.7 (Ubuntu) PHP/5.5.9-1ubuntu4.29 (internal dummy connection)"
::1 - - [06/Nov/2026:08:32:31 +0000] "OPTIONS * HTTP/1.0" 200 125 "-" "Apache/2.4.7 (Ubuntu) PHP/5.5.9-1ubuntu4.29 (internal dummy connection)"
::1 - - [06/Nov/2026:08:32:31 +0000] "OPTIONS * HTTP/1.0" 200 125 "-" "Apache/2.4.7 (Ubuntu) PHP/5.5.9-1ubuntu4.29 (internal dummy connection)"
::1 - - [06/Nov/2026:08:32:40 +0000] "OPTIONS * HTTP/1.0" 200 125 "-" "Apache/2.4.7 (Ubuntu) PHP/5.5.9-1ubuntu4.29 (internal dummy connection)"
::1 - - [06/Nov/2026:08:32:40 +0000] "OPTIONS * HTTP/1.0" 200 125 "-" "Apache/2.4.7 (Ubuntu) PHP/5.5.9-1ubuntu4.29 (internal dummy connection)"
::1 - - [06/Nov/2026:08:32:40 +0000] "OPTIONS * HTTP/1.0" 200 125 "-" "Apache/2.4.7 (Ubuntu) PHP/5.5.9-1ubuntu4.29 (internal dummy connection)"
::1 - - [06/Nov/2026:08:32:40 +0000] "OPTIONS * HTTP/1.0" 200 125 "-" "Apache/2.4.7 (Ubuntu) PHP/5.5.9-1ubuntu4.29 (internal dummy connection)"
::1 - - [06/Nov/2026:08:32:40 +0000] "OPTIONS * HTTP/1.0" 200 125 "-" "Apache/2.4.7 (Ubuntu) PHP/5.5.9-1ubuntu4.29 (internal dummy connection)"
::1 - - [06/Nov/2026:08:32:41 +0000] "OPTIONS * HTTP/1.0" 200 125 "-" "Apache/2.4.7 (Ubuntu) PHP/5.5.9-1ubuntu4.29 (internal dummy connection)"
::1 - - [06/Nov/2026:08:32:41 +0000] "OPTIONS * HTTP/1.0" 200 125 "-" "Apache/2.4.7 (Ubuntu) PHP/5.5.9-1ubuntu4.29 (internal dummy connection)"
::1 - - [06/Nov/2026:08:32:41 +0000] "OPTIONS * HTTP/1.0" 200 125 "-" "Apache/2.4.7 (Ubuntu) PHP/5.5.9-1ubuntu4.29 (internal dummy connection)"
::1 - - [06/Nov/2026:08:32:41 +0000] "OPTIONS * HTTP/1.0" 200 125 "-" "Apache/2.4.7 (Ubuntu) PHP/5.5.9-1ubuntu4.29 (internal dummy connection)"
::1 - - [06/Nov/2026:08:32:41 +0000] "OPTIONS * HTTP/1.0" 200 125 "-" "Apache/2.4.7 (Ubuntu) PHP/5.5.9-1ubuntu4.29 (internal dummy connection)"
root@ubuntu:~#
```

```
root@ubuntu:~# tail -n 20 /var/log/apache2/error.log
[Fri Nov 06 08:32:09.349139 2026] [mpm_prefork:notice] [pid 7739] AH00163: Apache/2.4.7 (Ubuntu) PHP/5.5.9-1ubuntu4.29 configured -- resuming normal
 operations
[Fri Nov 06 08:32:09.349189 2026] [core:notice] [pid 7739] AH00094: Command line: '/usr/sbin/apache2'
[Fri Nov 06 08:32:31.627544 2026] [mpm_prefork:notice] [pid 7739] AH00171: Graceful restart requested, doing restart
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.0.1. Set the 'ServerName' directive globally to
 suppress this message
[Fri Nov 06 08:32:32.522238 2026] [mpm_prefork:notice] [pid 7739] AH00163: Apache/2.4.7 (Ubuntu) PHP/5.5.9-1ubuntu4.29 configured -- resuming normal
 operations
[Fri Nov 06 08:32:32.522257 2026] [core:notice] [pid 7739] AH00094: Command line: '/usr/sbin/apache2'
[Fri Nov 06 08:32:40.729969 2026] [mpm_prefork:notice] [pid 7739] AH00171: Graceful restart requested, doing restart
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.0.1. Set the 'ServerName' directive globally to
 suppress this message
[Fri Nov 06 08:32:40.947774 2026] [mpm_prefork:notice] [pid 7739] AH00163: Apache/2.4.7 (Ubuntu) PHP/5.5.9-1ubuntu4.29 configured -- resuming normal
 operations
[Fri Nov 06 08:32:40.947787 2026] [core:notice] [pid 7739] AH00094: Command line: '/usr/sbin/apache2'
[Fri Nov 06 08:32:41.007254 2026] [mpm_prefork:notice] [pid 7739] AH00171: Graceful restart requested, doing restart
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.0.1. Set the 'ServerName' directive globally to
 suppress this message
[Fri Nov 06 08:32:41.087978 2026] [mpm_prefork:notice] [pid 7739] AH00163: Apache/2.4.7 (Ubuntu) PHP/5.5.9-1ubuntu4.29 configured -- resuming normal
 operations
[Fri Nov 06 08:32:41.087992 2026] [core:notice] [pid 7739] AH00094: Command line: '/usr/sbin/apache2'
[Fri Nov 06 08:32:52.873430 2026] [mpm_prefork:notice] [pid 7739] AH00169: caught SIGTERM, shutting down
[Fri Nov 06 08:32:54.107606 2026] [mpm_prefork:notice] [pid 9029] AH00163: Apache/2.4.7 (Ubuntu) PHP/5.5.9-1ubuntu4.29 configured -- resuming normal
 operations
[Fri Nov 06 08:32:54.107649 2026] [core:notice] [pid 9029] AH00094: Command line: '/usr/sbin/apache2'
[Fri Nov 06 08:36:06.824465 2026] [mpm_prefork:notice] [pid 9029] AH00169: caught SIGTERM, shutting down
[Fri Nov 06 08:36:08.105938 2026] [mpm_prefork:notice] [pid 9390] AH00163: Apache/2.4.7 (Ubuntu) PHP/5.5.9-1ubuntu4.29 OpenSSL/1.0.1f configured --
resuming normal operations
[Fri Nov 06 08:36:08.105969 2026] [core:notice] [pid 9390] AH00094: Command line: '/usr/sbin/apache2'
root@ubuntu:~#
```

B. Surveillance des événements Pure-FTPd

Les événements liés au serveur FTP (connexions virtuelles, échecs d'authentification, dépôts de fichiers) sont centralisés au niveau des journaux système Syslog / messages.

```
root@ubuntu:~# grep -i "pure-ftpd" /var/log/syslog | tail -n 20
root@ubuntu:~#
```

C. Surveillance de la sécurité système et des accès SSH

Le fichier auth.log conserve la trace de toutes les tentatives d'authentification système, de l'utilisation de la commande sudo et des sessions SSH distantes.

```
root@ubuntu:~# tail -n 20 /var/log/auth.log
Jun  4 09:54:48 ubuntu login[604]: pam_env(login:session): Unable to open env file: /etc/default/locale: No such file or directory
Jun  4 09:54:48 ubuntu login[604]: pam_unix(login:session): session opened for user root by LOGIN(uid=0)
Jun  4 09:54:48 ubuntu login[653]: ROOT LOGIN  on '/dev/tty1'
Jun  4 09:54:58 ubuntu login[604]: pam_unix(login:session): session closed for user root
Jun  4 09:54:59 ubuntu login[667]: pam_env(login:session): Unable to open env file: /etc/default/locale: No such file or directory
Jun  4 09:54:59 ubuntu login[667]: pam_unix(login:session): session opened for user user by LOGIN(uid=0)
Jun  4 09:55:00 ubuntu login[667]: pam_unix(login:session): session closed for user user
Jun  4 09:55:03 ubuntu login[692]: pam_env(login:session): Unable to open env file: /etc/default/locale: No such file or directory
Jun  4 09:55:03 ubuntu login[692]: pam_unix(login:session): session opened for user root by LOGIN(uid=0)
Jun  4 09:55:03 ubuntu login[706]: ROOT LOGIN  on '/dev/tty1'
Jun  4 09:56:20 ubuntu login[595]: pam_env(login:session): Unable to open env file: /etc/default/locale: No such file or directory
Jun  4 09:56:20 ubuntu login[595]: pam_unix(login:session): session opened for user root by LOGIN(uid=0)
Jun  4 09:56:20 ubuntu login[653]: ROOT LOGIN  on '/dev/tty1'
Jun  4 09:59:26 ubuntu login[609]: pam_env(login:session): Unable to open env file: /etc/default/locale: No such file or directory
Jun  4 09:59:26 ubuntu login[609]: pam_unix(login:session): session opened for user root by LOGIN(uid=0)
Jun  4 09:59:26 ubuntu login[654]: ROOT LOGIN  on '/dev/tty1'
root@ubuntu:~#
```

9. Tableau de Synthèse des Services et Infrastructure

Service	Démon	Port	Protocole	Fichier de Configuration Principal	Statut
Administration SSH	sshd	22	TCP / SSH	/etc/ssh/sshd_config	Actif (Sécurisé)
Serveur Web Standard	apache2	80	TCP / HTTP	/etc/apache2/sites-available/000-default.conf	Redirection 301
Serveur Web Sécurisé	apache2	443	TCP / HTTPS (TLS)	/etc/apache2/sites-available/gsb-ssl.conf	Actif (Sécurisé)
Serveur de Fichiers	pure-ftpd	21	TCP / FTPS (TLS)	/etc/pure-ftpd/conf/ (PureDB, TLS)	Actif (Sécurisé)
Base de Données	mysqld	3306	TCP / MySQL	/etc/mysql/my.cnf	Actif (Local)